APIH Corporativo · Propuesta técnica para revisión con TI

Oct 16, 2026 · @Christian

La propuesta en una página

BISE pone a disposición de TI una propuesta técnica de APIH Corporativo, ya construida y probada en local, para revisarla en conjunto. Si les acomoda, la meta es tener el ambiente dev al 04-11 y producción el 27-11.

- **Qué es:** plataforma de gestión del portafolio de BISE (propuestas, proyectos, fases, hitos, riesgos, decisiones y comités). Reemplaza al Prototipo, que queda congelado.
- **Arquitectura:** las 3 capas recomendadas por TI: Static Web App con Entra ID, API en Azure Functions con las reglas de negocio y Azure SQL.
- **Estado:** construida y probada en local, con 63 pruebas automáticas y 130.317 comparaciones idénticas con el Prototipo. Falta validarla en Azure.
- **Seguridad:** cuenta Aramark con asignación requerida, 3 roles por grupos de Entra, sin contraseñas, historial de cambios y auditoría.
- **Datos:** migración desde el Prototipo (hoy en Supabase, fuera de Aramark) con un script validado; vistas para Power BI.
- **Lo que haría TI:** 6 pasos, alrededor de una hora por ambiente, todos escritos como código.
- **15 puntos para revisar,** cada uno con propuesta y alternativa: patrón CMDB, backend, base de datos, hosting, roles, Teams, repositorio, seguridad, notificaciones, suscripción, directorio, IA, dirección web, soporte y clasificación de datos.
- **Fechas clave:** comentarios de TI 21-10 · ambiente dev 04-11 · demo 10-11 · seguridad 24-11 · producción 27-11 · retiro del Prototipo 03-12.
- **Principal riesgo:** que la habilitación en Azure tome más de una semana; por eso todo se entrega listo para desplegar.

Las secciones siguientes detallan cada tema; el anexo trae el plan completo de 21 hitos.

Puntos para revisar con TI

Cada punto trae una propuesta y una alternativa. Las ajustamos con gusto a lo que TI defina como estándar.

#	Tema	Propuesta	Si TI prefiere otra cosa
1	Patrón de referencia	Seguir el enfoque del Catálogo CMDB; pedimos su documentación o repositorio	Ajustamos al patrón que indiquen
2	Backend	API en Node.js 20 sobre Azure Functions, porque reutiliza las reglas ya probadas	Con .NET se reescribe solo la API; contrato y pruebas siguen sirviendo
3	Base de datos	Azure SQL serverless, solo autenticación Entra ID, administrada por TI	Otro SKU o servidor existente de TI
4	Hosting y ambientes	Azure Static Web App Standard + Function App enlazada; ambientes dev y prod	Agregar qa
5	Roles	Grupos de Entra: APIH-Admin, APIH-Editor y APIH-Lectura, creados por TI; BISE mantiene la membresía	Grupos existentes de TI
6	Teams	Primero web con Entra ID; después app en el catálogo de la organización	Sin Teams en esta etapa
7	Repositorio	Migrar el código al repositorio corporativo que indique TI, con su pipeline	GitHub o Azure DevOps, ambos sirven
8	Revisión de seguridad	Solicitarla desde el 21-10 para tenerla antes del 24-11	Indicar el procedimiento

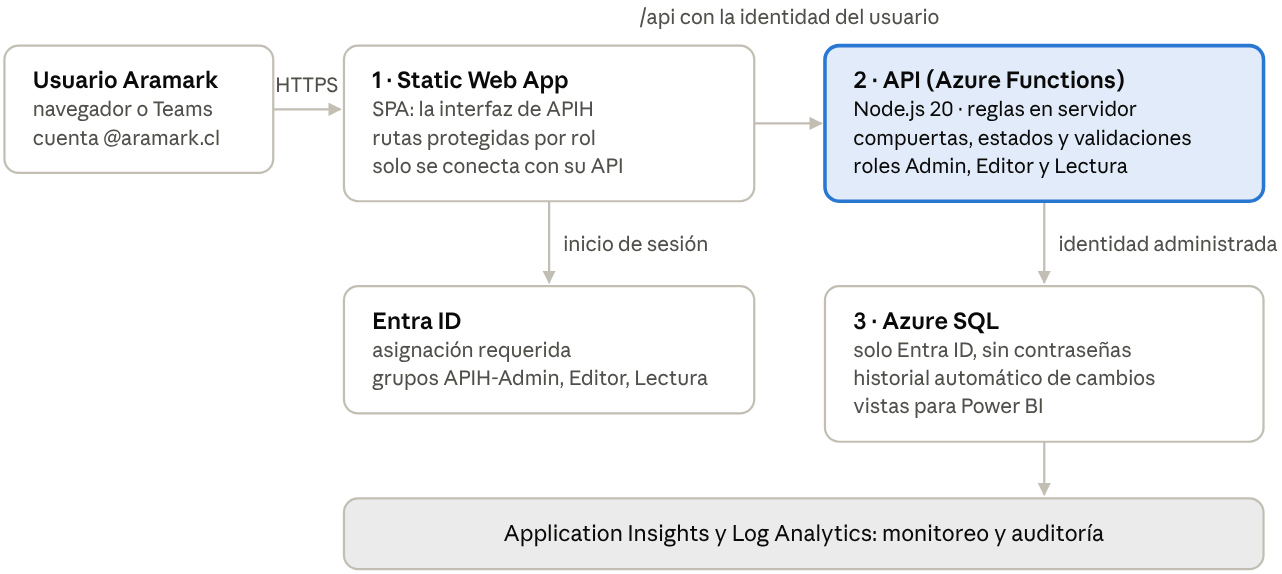
#	Tema	Propuesta	Si TI prefiere otra cosa
9	Notificaciones	Avisos por correo y por Teams (vencimientos, compuertas, cambios de estado); consultamos qué mecanismo prefiere TI, por ejemplo un servicio de correo corporativo o un webhook de Teams	Solo avisos dentro de la aplicación en esta etapa
10	Suscripción de Azure	Consultamos en qué suscripción de Azure se crean los recursos de dev y prod	La que TI indique
11	Directorio de personas	Tomar líderes, sponsors y responsables del directorio de Entra ID (permiso de Microsoft Graph de solo lectura, con aprobación de un administrador)	Mantener la lista propia de usuarios de APIH
12	Uso de IA	Consultamos si se permite usar IA con datos del portafolio y con qué servicio (por ejemplo Azure OpenAI), incluida una identidad de servicio para tareas automatizadas	Mantener el uso actual: exportación e importación manual de archivos
13	Dirección web	Una dirección propia, por ejemplo apih.aramark.cl (DNS y certificado de TI)	La dirección automática de Azure (…azurestaticapps.net)
14	Operación y soporte	Acordar entre BISE y TI quién monitorea, atiende incidentes, restaura respaldos y gestiona accesos en producción	El modelo de soporte que TI use para aplicaciones internas

#	Tema	Propuesta	Si TI prefiere otra cosa
15	Clasificación de datos	Consultamos la clasificación de los datos (nombres, correos, montos, riesgos) y la política de retención que aplica	La política estándar de TI

Arquitectura propuesta

La arquitectura sigue las 3 capas que recomendó TI, con el mismo enfoque del Catálogo CMDB.

Las reglas viven en la API y nadie entra sin Entra ID



arquitectura · 3 capas + Entra ID

El usuario solo ve la Static Web App; la API acepta únicamente llamadas que vienen de ella con la identidad verificada por Entra ID. Toda regla de negocio se decide en la API, y la base solo acepta a la API.

Qué ya está construido y probado

Las 3 capas están construidas y pasan 63 pruebas automáticas, además de 130.317 comparaciones contra el Prototipo. Cada entrega es una versión C con su registro y sus decisiones documentadas.

Versión	Entrega	Cómo se probó
C2.3	Infraestructura como código (Bicep), registro Entra ID, pipeline, documento de seguridad	Revisión; se valida en el primer despliegue dev
C2.2	SPA corporativa: sesión de Static Web Apps + Entra ID, conectada a la API	Prueba de navegador completa: alta, edición, rechazo de compuerta, conflicto y recarga
C2.1	Azure SQL: esquema, historial automático, vistas de reporte, migración	Contrato completo contra la capa SQL (simulada) y migración del plan real
C2.0	API Node.js con todas las reglas en servidor y 3 roles	17 casos de contrato por servicio y por HTTP + 8 de seguridad
C1.4	Compuertas de fase, hitos y riesgos en el núcleo compartido	62.061 casos idénticos al Prototipo
C1.1	Contrato de Iniciativa: datos, 8 operaciones, 10 reglas, errores	Pruebas de contrato
C1.0	Núcleo de fechas y riesgo	68.256 casos idénticos al Prototipo

Las reglas de negocio existen una sola vez, en un núcleo compartido que usa la API. Las pruebas de equivalencia garantizan que se comportan igual que en el Prototipo que hoy usa BISE.

Seguridad

No hay contraseñas en la aplicación ni en el código: el acceso es con la cuenta Aramark y la API entra a Azure SQL con identidad administrada.

Control	Cómo se cumple
Acceso	Entra ID con asignación requerida: solo miembros de APIH-Admin, APIH-Editor o APIH-Lectura; cuentas fuera de @aramark.cl se rechazan
Autorización	Rol verificado en las rutas de Static Web Apps y otra vez en cada operación de la API
Reglas de negocio	Todas en el servidor: validaciones, compuertas de fase, estados y permisos
Trazabilidad	Quién modificó sale de la sesión, no del navegador; Azure SQL guarda el historial de cada cambio y la auditoría va a Log Analytics
Datos	Azure SQL solo con Entra ID, TLS 1.2+, cifrado en reposo, respaldo automático
Navegador	La SPA solo puede conectarse a su propia API; encabezados de seguridad; inserción en Teams/Office permitida
Secretos y despliegue	El secreto de Entra vive solo en Azure; el pipeline corre las pruebas y despliega sin secretos guardados (OIDC)

El detalle, con el cruce contra OWASP Top 10, está en `docs/seguridad.md` del repositorio. Quedan 4 pendientes de producción en la sección de limitaciones.

Datos y migración desde el Prototipo

Los datos actuales pasan a Azure SQL con un script generado y validado, en una sola transacción y conservando los identificadores.

- **Modelo:** cada registro guarda el objeto ya validado por la API, más columnas indexadas para filtros y reportes. Agregar un campo no exige cambiar la base.
- **Historial:** tablas temporales de Azure SQL; cada cambio queda con fecha y autor, sin código adicional.
- **Reportes:** vistas listas para Power BI (iniciativas, áreas, hitos y riesgos).

- **Migración:** se toma el respaldo JSON del Prototipo y se genera el script de carga. Los registros inválidos no se migran y quedan informados con su motivo. Probado con el plan real: 2 iniciativas, 30 hitos y 11 riesgos.

Los datos del Prototipo hoy viven en Supabase, fuera de Aramark. Por eso conviene migrar lo antes posible y no cargar datos sensibles mientras tanto.

Lo que TI debe habilitar

Son 6 pasos, alrededor de una hora por ambiente; todo está escrito como código y documentado en `infra/README.md`.

1. Crear el grupo de recursos y los grupos de Entra APIH-Admin, APIH-Editor y APIH-Lectura, más el grupo administrador de Azure SQL.
2. Desplegar `infra/main.bicep`: Static Web App, Function App, Azure SQL, Application Insights y Storage.
3. Ejecutar `infra/entra-registro.sh`: registro de la app, asignación requerida y grupos. El secreto queda solo en Azure.
4. En Azure SQL, como administrador Entra: correr `db/azure-sql/001_esquema.sql` y `002_permisos.sql`.
5. Configurar el pipeline en el repositorio corporativo: credenciales OIDC y token de la Static Web App.
6. Validar: correr el contrato completo contra la base real (`tests/contract/run-azure-sql.js`) y abrir la URL.

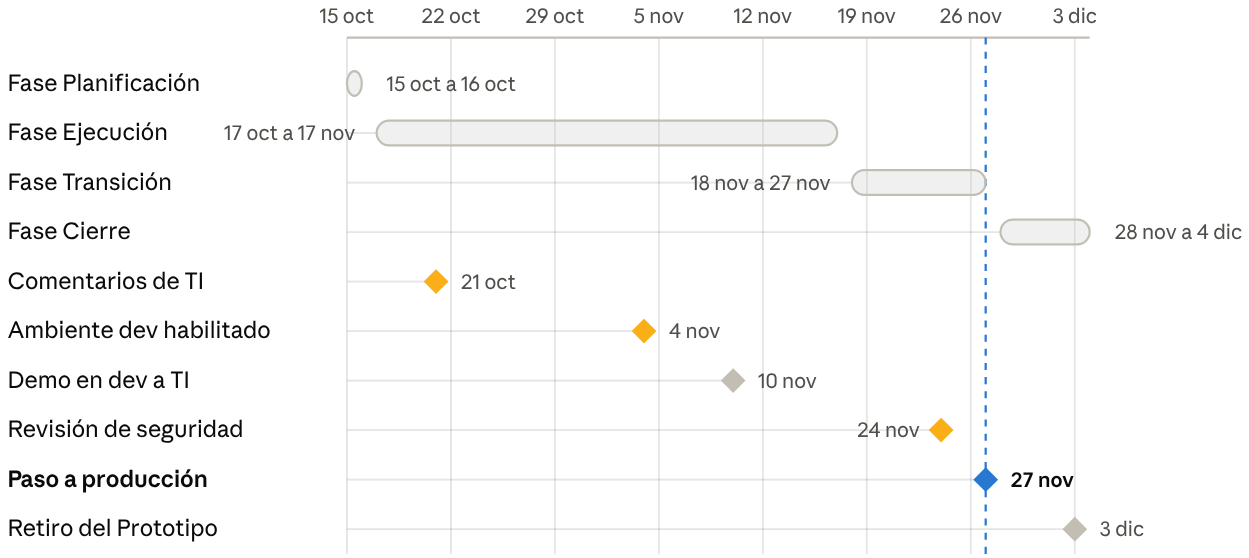
Para producción se repiten los mismos pasos con los parámetros de prod.

Plan, hitos y riesgos

Producción el 27-11, 25 días antes de la meta original (22-12), si TI habilita el ambiente dev al 04-11. Los hitos que dependen de TI son la ruta crítica.

Producción el 27 nov si TI habilita dev al 4 nov

Fases y hitos clave, 2026 · en naranjo, lo que depende de TI



plan · fases e hitos clave

Riesgo	Exposición (1–25)	Revisión	Mitigación
La infraestructura de TI tarda más de 1 semana	16	04-11	Todo entregado como código; ambiente local equivalente para no detener el desarrollo
Los comentarios de TI requieren más tiempo del previsto	15	21-10	Propuesta concreta y documentada para facilitar la revisión; ajustar el plan en conjunto con TI
La revisión de seguridad retrasa producción	12	10-11	Documento de seguridad entregado con esta propuesta; pedir la revisión desde el 21-10
TI define otro stack de backend (.NET)	9	23-10	Contrato y pruebas independientes del stack; solo se rehace la API

Limitaciones y pendientes

Lo construido se probó completo en local; lo que depende de Azure se valida en el primer despliegue dev.

A validar en dev (no había acceso a Azure):

- El script de Azure SQL contra una base real: columnas calculadas en tablas temporales y permisos de secuencias.
- Las plantillas Bicep y el registro de Entra.
- La librería oficial de Azure Functions; el adaptador se probó con un sustituto de la misma interfaz.

Pendientes de producción (acordar con TI):

1. Red privada: VNet y private endpoint para Azure SQL y la Function App.
2. Revisión de seguridad o pentest de TI antes del 24-11.
3. Rotación anual del secreto de Entra.
4. Política de retención del historial.

Alcance funcional: iniciativas, hitos y riesgos ya tienen reglas en el servidor. Decisiones, bitácora, comités, compromisos, cambios, notas y documentos se guardan con permisos por rol y tendrán contrato propio en versiones siguientes. Los roles finos del Prototipo (Gasto, áreas) también quedan para después.

Evidencia de aceleración

Las 3 capas, la documentación y la infraestructura como código se construyeron en una sesión de trabajo de unas 4 horas: del 15-10 a las 22:05 al 16-10 a las 01:54. El método combina IA con contratos, pruebas automáticas y versiones pequeñas publicadas apenas se prueban.

Hora (registro de versiones)	Versión	Entrega
16-10 01:54	C2.3	Infraestructura como código, seguridad, pipeline
16-10 01:51	C2.2	SPA corporativa con Entra ID conectada a la API
16-10 01:43	C2.1	Azure SQL y migración
16-10 01:40	C2.0	API con reglas en servidor y roles

Hora (registro de versiones)	Versión	Entrega
16-10 01:35	C1.4	Compuertas, hitos y riesgos en el núcleo
16-10 01:28	V22.54	Prototipo: planificación en la ficha y siguientes pasos
16-10 00:53	V22.53	Prototipo: vista Fases con 4 miradas
16-10 00:17	C1.3	Plan acelerado: producción 27-11 (antes 22-12)
15-10 23:45	C1.2	Registro de versiones y decisiones
15-10 22:19	C1.1	Contrato de Iniciativa
15-10 22:13	C1.0	Núcleo de fechas y riesgo

Si a TI le parece útil, podemos comparar juntos estos tiempos con su estimación habitual para un alcance equivalente. El informe de cierre (04-12) registrará las horas reales de cada versión.

Código y documentación: repositorio `Cetolosa/APIH` (se migra al repositorio corporativo que indique TI). Decisiones de arquitectura en `docs/decisiones/` (ADR-001 a ADR-010); registro de versiones en `CHANGELOG.md`.

Anexo · Plan completo del proyecto

El plan tiene 21 hitos en 4 fases; 4 cumplidos al 16-10 y 3 a cargo de TI. Fechas sujetas a los comentarios de TI.

Fecha	Fase	Hito	Responsable	Estado
15-10	Planificación	Plan y análisis de brechas	BISE	Cumplido
15-10	Planificación	C1.0 · Núcleo de fechas y riesgo	BISE	Cumplido
15-10	Planificación	C1.1 · Contrato de Iniciativa y pruebas de contrato	BISE	Cumplido
15-10	Planificación	C1.2 · Registro de versiones, decisiones y traspaso	BISE	Cumplido
16-10	Planificación	C1.3 · Plan acelerado aprobado	BISE	Pendiente

Fecha	Fase	Hito	Responsable	Estado
16-10	Planificación	Envío de la propuesta técnica a TI	BISE	Pendiente
20-10	Ejecución	C1.4 · Contratos de Hitos y Riesgos y compuertas de fase	BISE	Pendiente
21-10	Ejecución	Comentarios de TI sobre la propuesta	TI	Pendiente
23-10	Ejecución	C1.5 · Contratos de decisiones, compromisos, bitácora y comités	BISE	Pendiente
28-10	Ejecución	C2.0 · API sobre el núcleo, pruebas de contrato en verde	BISE	Pendiente
30-10	Ejecución	C2.1 · Esquema Azure SQL y migración de datos	BISE	Pendiente
04-11	Ejecución	Ambiente dev habilitado (Entra ID, Azure SQL, Static Web App, pipeline)	TI	Pendiente
05-11	Ejecución	C2.2 · SPA con Entra ID conectada a la API	BISE	Pendiente
10-11	Ejecución	Despliegue en dev y demo a TI	BISE	Pendiente
17-11	Ejecución	C3.0 · Funciones diferidas: Pronóstico financiero, Ruta crítica, Escenarios	BISE	Pendiente
20-11	Transición	Pruebas de usuario (UAT) y migración final de datos	BISE	Pendiente
24-11	Transición	Revisión de seguridad de TI	TI	Pendiente
27-11	Transición	Paso a producción (web con Entra ID)	BISE y TI	Pendiente
01-12	Cierre	Publicación en Teams	BISE y TI	Pendiente
03-12	Cierre	Retiro del Prototipo y de Supabase	BISE	Pendiente
04-12	Cierre	Informe de aceleración: horas reales vs. estimación	BISE	Pendiente

C1.4 a C2.2 ya se adelantaron en la versión construida en local (sección «Qué ya está construido y probado»). Se dan por cumplidas al validarse en el ambiente dev.